Universidad Privada Domingo Savio
Facultad de Ingeniería
Ingeniería en Sistemas



Detección y Vigilancia de Vulnerabilidades en Servidor Corporativo

Joaquin Alessandro Felipez Rojas
Nicolas Sebastian Reguerin Meneses
David Willy Cruz Huanca

Asignatura: Seguridad Informática
Docente: Jose Abraham Mita Huanca
Fecha de entrega: 27/10/2026

Equipo: Grupo 1 Sudoers

Cochabamba–Bolivia
2026

Índice

CAPÍTULO I

ENTORNO DE PRUEBAS, OBJETIVOS Y MARCO TEÓRICO **1**

1.1 Introducción al Entorno de Evaluación 1

1.2 Objetivos de la Evaluación de Seguridad 1

1.2.1 Objetivo General 1

1.2.2 Objetivos Específicos 1

1.3 Alcance y Límites de la Evaluación 2

1.3.1 Alcance del Proyecto 2

1.3.2 Límites y Restricciones Operativas 3

1.4 Marco Teórico del Arsenal Tecnológico de Seguridad 4

1.4.1 Nmap (Network Mapper) 4

1.4.2 Wireshark: Análisis Forense y de Protocolos de Red 5

1.4.3 OWASP ZAP (Zed Attack Proxy) 6

1.4.4 Suricata IDS/IPS 6

1.4.5 EveBox: Consola y Gestión de Telemetría en Tiempo Real 7

1.5 Definición del Equipo Objetivo (Target) 7

1.5.1 Ficha Técnica del Sistema Objetivo 7

1.5.2 Matriz de Servicios y Puertos Expuestos 8

1.6 Topología de Red del Escenario de Pruebas 10

CAPÍTULO II

METODOLOGÍA Y EVIDENCIAS DE AUDITORÍA **11**

2.1 Metodología de Evaluación y Procedimiento Técnico 11

2.2 Reglas de Detección y Prevención Configuradas en Suricata IDS/IPS 11

2.2.1 Reglas de Detección Pasiva (Modo IDS – Acción ALERT) 12

2.2.2 Reglas de Prevención Activa en Línea (Modo IPS – Acción DROP) 14

2.3 Evidencias de la Auditoría Dinámica Web y Monitoreo Defensivo 15

2.3.1 Auditoría de Aplicaciones Web con OWASP ZAP 16

2.3.2 Supervisión de Amenazas en Tiempo Real con EveBox 17

2.3.3 Comportamiento Defensivo del Servidor ante Escaneos Agresivos (Anti-Nmap) 18

2.3.4 Plataforma Institucional de Firma Digital y Validación Criptográfica (Puerto 8090) 19

2.3.4.1 Mecanismos de Operación y Funcionamiento Criptográfico 20

CAPÍTULO III

HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES 23

3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas 23

3.2 Evidencia Técnica Única del Escaneo (Nmap NSE) 24

3.2.1 Evasión Exitosa de las Reglas Defensivas de Nginx 29

3.3 División y Análisis Pormenorizado de Cada Vulnerabilidad 30

3.3.1 VULN-01: Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP y Submission 30

3.3.2 VULN-02: Denegación de Servicio por Solicitud de Múltiples Rangos de Bytes (CVE-2011-3192) 31

3.3.3 VULN-03: Método y Modo de Depuración Activo en Webmail (http-aspnet-debug) 32

3.3.4 VULN-04: Exposición Pública del Puerto PostgreSQL (5432/tcp) 32

3.3.5 VULN-05: Exposición de Servicios Administrativos y Web en Texto Plano (HTTP) 33

3.3.6 DEF-01: Neutralización Activa de Inyección SQL y Exploits por WAF/IPS (Script Failed) 34

CAPÍTULO IV

MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO 35

4.1 Estrategia Integral de Remediación y Endurecimiento 35

4.2 Remediación Específica por Vulnerabilidad Identificada 35

4.2.1 Remediación VULN-01: Exclusión de Suites Anónimas Diffie-Hellman en Postfix 35

4.2.2 Remediación VULN-02: Mitigación de Denegación de Servicio Byte-Range (CVE-2011-3192) 36

4.2.3 Remediación VULN-03: Supresión de Métodos DEBUG y Ocultamiento de Banners 37

4.2.4 Remediación VULN-04: Aislamiento del Motor de Base de Datos PostgreSQL (5432) 37

4.2.5 Remediación VULN-05: Cifrado y Canalización Segura de Aplicaciones Web 38

4.2.6 Consolidación DEF-01: Mantenimiento del WAF Anti-SQLi y Suricata IPS 39

CONCLUSIONES 40

5. Conclusiones del Ejercicio de Auditoría 40

5. Recomendaciones para la Infraestructura y Práctica Operativa 41

REFERENCIAS **43**

Índice de tablas

TABLA 1: Ficha Técnica del Servidor Objetivo (Target) 8

TABLA 2: Matriz de Servicios y Puertos en Evaluación 9

TABLA 3: Reglas de Detección e Inspección Pasiva en Suricata (Modo IDS – Parte 1) 13

TABLA 4: Reglas de Detección e Inspección Pasiva en Suricata (Modo IDS – Parte 2) 14

TABLA 5: Reglas de Prevención Activa y Bloqueo en Línea en Suricata (Modo IPS) 15

TABLA 6: Matriz Consolidada de Vulnerabilidades y Hallazgos del Escaneo Nmap NSE 24

Índice de figuras

FIGURA 1: Diagrama de Topología del Entorno de Auditoría y Escaneo 10

FIGURA 2: Escaneo Dinámico en Vivo con OWASP ZAP sobre Uyuni Way Web (Puerto 8085) 16

FIGURA 3: Alertas de Nivel Medio (Color Naranja) Detectadas por OWASP ZAP 16

FIGURA 4: Panel de Eventos y Alertas de Seguridad en Tiempo Real en EveBox 17

FIGURA 5: Estancamiento de Nmap NSE al 99.58 % por Efecto Tarpitting Defensivo en Nginx 18

FIGURA 6: Interfaz de Autenticación y Acceso Seguro a la Plataforma de Firma Digital (Puerto 8090) 19

FIGURA 7: Evidencia Gráfica del Escaneo de Vulnerabilidades con Evasión Nmap NSE 30

CAPÍTULO I

ENTORNO DE PRUEBAS, OBJETIVOS Y MARCO TEÓRICO

1.1 Introducción al Entorno de Evaluación

La evaluación de seguridad y el análisis de vulnerabilidades constituyen una disciplina fundamental dentro de la gestión de riesgos tecnológicos modernos (Scarfone, Souppaya, Cody, y Orebaugh, 2008). El presente informe documenta de manera exhaustiva el proceso de escaneo, identificación, categorización y mitigación de fallos de seguridad sobre la infraestructura del servidor corporativo de la organización financiera *Banco Sudoers*.

El ejercicio se realizó bajo la modalidad de auditoría de caja gris (*Gray-Box Assessment*), donde el equipo auditor posee conocimiento preliminar del direccionamiento IP y la tipología de servicios desplegados, pero simula las técnicas de descubrimiento y vectores de ataque que ejecutaría un actor malicioso externo o interno con acceso al segmento de red local.

1.2 Objetivos de la Evaluación de Seguridad

1.2.1 Objetivo General

Realizar la detección, vigilancia técnica y análisis integral de vulnerabilidades en el servidor corporativo (`dc1.sudoers.lan`), evaluando la postura defensiva y la superficie de exposición de sus servicios de infraestructura y aplicaciones web mediante técnicas de auditoría de caja gris, pruebas de penetración no intrusivas y monitoreo continuo de telemetría de red.

1.2.2 Objetivos Específicos

1. **Explorar y mapear la superficie de ataque perimetral:** Descubrir los puertos abiertos, servicios en ejecución, versiones de software y componentes del sistema operativo en el servidor objetivo mediante técnicas de escaneo activo con Nmap, aplicando estrategias de evasión táctica (*Decoy Scanning*) para superar los mecanismos de retardo y filtrado perimetral.
2. **Identificar y clasificar vulnerabilidades en servicios e infraestructura:** Ejecutar

análisis automatizados con el motor *Nmap Scripting Engine* (NSE) para detectar fallos de configuración criptográfica, debilidades en servicios de correo, vectores de denegación de servicio y exposiciones indebidas de bases de datos, categorizando los hallazgos según el estándar CVSS v3.1 y las taxonomías CWE y CVE.

3. **Evaluar la seguridad de aplicaciones web mediante auditoría dinámica (DAST):** Realizar escaneos activos y pasivos sobre los aplicativos web desplegados mediante OWASP ZAP, identificando debilidades a nivel de cabeceras de seguridad, métodos HTTP riesgosos y posibles vectores de inyección o fuga de información técnica.
4. **Vigilar e inspeccionar el tráfico de red en tiempo real:** Monitorizar el flujo de paquetes y auditar el comportamiento defensivo del sistema ante las sondas ofensivas utilizando el motor IDS/IPS Suricata y la consola de telemetría EveBox, validando la eficacia de las firmas de detección y las políticas de bloqueo en línea.
5. **Verificar la confidencialidad criptográfica en tránsito:** Analizar mediante Wireshark los paquetes capturados en el segmento de red para confirmar si las credenciales, sesiones y datos corporativos viajan protegidos por protocolos cifrados modernos (TLS) o si se transmiten en texto claro sin autenticación adecuada.
6. **Formular e implementar directivas de mitigación y endurecimiento (*hardening*):** Diseñar planes de remediación técnica y recomendaciones de configuración segura para cada vulnerabilidad descubierta, fortaleciendo el cortafuegos, restringiendo el acceso a servicios críticos y asegurando la resiliencia operativa del servidor.

1.3 Alcance y Límites de la Evaluación

1.3.1 Alcance del Proyecto

El alcance técnico y operativo de la presente evaluación de seguridad comprende los siguientes aspectos:

- **Infraestructura y Host Objetivo:** Auditoría directa sobre el servidor corporativo central `dc1.sudoers.lan` (`192.168.100.85`), analizando tanto los componentes nativos

del sistema operativo GNU/Linux base como la capa de servicios contenerizados desplegados bajo Docker.

- **Superficie de Exposición Auditada:** Evaluación exhaustiva de 16 servicios y puertos TCP expuestos, cubriendo aplicaciones web (Nginx, Roundcube, TinyFileManager, Uyuni Way), servicios de correo (Postfix SMTP/Submission, Dovecot IMAP/POP3), base de datos relacional (PostgreSQL en 5432) y consolas administrativas o de monitoreo (OpenSSH, Portainer, Grafana y EveBox).
- **Metodología de Auditoría:** Ejecución de pruebas bajo la modalidad de caja gris (*Gray-Box Assessment*) desde una estación auditora dedicada (Kali Linux en `192.168.100.50`) ubicada en el mismo segmento de red conmutada.
- **Arsenal Tecnológico Defensivo y Ofensivo:** Exploración de puertos y vulnerabilidades con Nmap NSE aplicando evasión por señuelos (*Decoy Scanning*), análisis dinámico web DAST con OWASP ZAP, verificación de paquetes y cifrado con Wireshark, y supervisión continua de alertas mediante el motor Suricata IDS/IPS y la consola EveBox.
- **Propuesta de Remediación:** Diseño, formulación y documentación de medidas técnicas de mitigación y endurecimiento (*hardening*) para cada fallo detectado.

1.3.2 Límites y Restricciones Operativas

Con el fin de garantizar la integridad del servidor, evitar la denegación involuntaria de servicios y respetar el marco ético y académico, se establecieron las siguientes restricciones:

- **Exclusión de Ataques DoS/DDoS Volumétricos Destructivos:** No se llevaron a cabo ataques de inundación masiva ni de saturación física de ancho de banda que pudieran causar caídas permanentes del hardware o corrupción irreversible del sistema de archivos.
- **Evaluaciones de Explotación No Destructiva:** Las pruebas de inyección de código (SQLi, XSS, Path Traversal) se limitaron estrictamente a la verificación empírica de la existencia del fallo mediante sondas benignas y comprobaciones no intrusivas, sin

alterar, sustraer ni destruir registros en la base de datos o en los contenedores.

- **Restricción al Segmento de Red Local de Pruebas:** La auditoría se circunscribió de forma exclusiva al segmento LAN `192.168.100.0/24`, sin interacción ni propagación de tráfico hacia redes corporativas externas ni proveedores de Internet.
- **Omisión de Vectores de Ingeniería Social y Físicos:** El ejercicio se enfocó estrictamente en la postura lógica de red y aplicaciones, descartando pruebas de ingeniería social al personal, ataques de *phishing* o intrusiones físicas al host.
- **Limitaciones por Equipamiento Físico de Red:** Ante la ausencia de infraestructura de switching y routing corporativo administrable (con soporte para VLANs 802.1Q dedicadas y firewalls perimetrales de hardware), la segmentación se gestionó lógicamente mediante `nftables` y subredes internas de Docker, restringiendo la implementación de una zona desmilitarizada (DMZ) física.

1.4 Marco Teórico del Arsenal Tecnológico de Seguridad

La evaluación de la postura de seguridad, la detección de vulnerabilidades y la verificación de las capacidades de respuesta defensiva demandan la integración coordinada de herramientas especializadas en las diferentes capas del modelo OSI (Scarfone y cols., 2008). A continuación se desarrollan los fundamentos conceptuales de las herramientas aplicadas en el presente ejercicio.

1.4.1 Nmap (Network Mapper)

Nmap constituye el estándar de facto en exploración de redes, auditoría de puertos y evaluación de superficies de ataque perimetral (Lyon, 2009). Opera mediante la emisión deliberada de paquetes IP crudos para determinar qué equipos están activos en el segmento, qué puertos TCP y UDP se encuentran abiertos, qué servicios y versiones de software responden, y qué sistema operativo subyace en el host.

Dentro de sus capacidades más avanzadas destaca el **Nmap Scripting Engine (NSE)**, el

cual permite automatizar tareas complejas de auditoría mediante scripts desarrollados en lenguaje Lua. En este proyecto se utilizó la categoría `vuln` para interrogar la presencia de fallos conocidos y debilidades de configuración.

Asimismo, Nmap dispone de mecanismos para evaluación en entornos restringidos por cortafuegos e IPS, tales como la generación de señuelos aleatorios (*Decoy Scanning* mediante `-D RND:20`), técnica que intercala la dirección IP real del atacante entre múltiples direcciones IP falsas generadas aleatoriamente, dificultando la correlación del origen de la sonda por parte de los sensores defensivos.

1.4.2 Wireshark: Análisis Forense y de Protocolos de Red

Wireshark es el analizador de protocolos de red y de paquetes de código abierto más utilizado a nivel mundial (Sanders, 2020). Permite capturar e interactuar con el tráfico que atraviesa una interfaz de red física o virtual en tiempo real, operando en modo promiscuo.

Sus capacidades conceptuales clave comprenden:

- **Inspección Profunda de Capas:** Decodificación completa de tramas desde la capa de enlace (Ethernet) hasta protocolos de aplicación (HTTP, DNS, SMTP, TLS, SMB, LDAP).
- **Filtros de Captura y Visualización:** Utilización de filtros BPF (*Berkeley Packet Filters*) para aislar flujos sospechosos y reglas de visualización para reconstruir sesiones TCP (*Follow TCP Stream*).
- **Verificación de Confidencialidad Criptográfica:** Comprobación empírica de si la información sensible (credenciales, cookies de sesión, mensajes de correo) transita en texto plano (HTTP, POP3, IMAP) o si se encuentra encapsulada dentro de canales criptográficos robustos (TLS 1.2/1.3).

1.4.3 OWASP ZAP (Zed Attack Proxy)

OWASP ZAP (Zed Attack Proxy) es una plataforma integral de pruebas de seguridad dinámicas para aplicaciones web (DAST – *Dynamic Application Security Testing*), mantenida por la comunidad global de OWASP (van der Stock, Glas, Smithline, y Gigler, 2021). Funciona como un *proxy* de interceptación intercalado entre el navegador del auditor y la aplicación web objetivo.

Entre sus módulos de operación destacan:

- **Spider / Rastreador Web:** Mapea automáticamente la estructura de la aplicación, formularios y endpoints navegables.
- **Escaneo Pasivo:** Analiza las respuestas HTTP sin enviar cargas adicionales, identificando de manera no intrusiva problemas como la ausencia de cabeceras de seguridad (`Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`) o cookies carentes de atributos `Secure` y `HttpOnly`.
- **Escaneo Activo:** Inyecta vectores de prueba dirigidos contra los parámetros de la aplicación para detectar inyecciones SQL (SQLi), Cross-Site Scripting (XSS), Local File Inclusion (LFI) y debilidades de control de acceso.
- **Clasificación de Alertas por Código de Color:** ZAP jerarquiza los hallazgos en cuatro niveles de riesgo: Rojo (*High Risk*), Naranja (*Medium Risk*), Amarillo (*Low Risk*) y Azul (*Informational*).

1.4.4 Suricata IDS/IPS

Suricata es un motor de seguridad de red de código abierto de última generación, capaz de operar como sistema de detección de intrusos (NIDS) y como sistema de prevención en línea (NIPS) (Open Information Security Foundation (OISF), 2024). Su arquitectura multi-hilo (*multi-threaded*) optimiza el procesamiento paralelo del tráfico en interfaces de alta velocidad.

Suricata implementa inspección profunda de paquetes (DPI) y análisis contextual de

protocolos (HTTP, TLS, DNS, SSH, SMB). Su motor compara las firmas del tráfico en tránsito contra reglas estandarizadas (como las reglas bancarias personalizadas o los conjuntos *Emerging Threats*), pudiendo alertar pasivamente o descartar paquetes (`DROP`) en tiempo real cuando se acopla a las colas `NFQUEUE` del cortafuegos `nftables`.

1.4.5 EveBox: Consola y Gestión de Telemetría en Tiempo Real

EveBox es la interfaz web gráfica diseñada para la correlación, filtrado y gestión de eventos emitidos por el motor Suricata a través de su archivo de registro estructurado `eve.json` (Open Information Security Foundation (OISF), 2024).

EveBox proporciona tableros en tiempo real con líneas temporales de incidentes, clasificación por severidad, gráficos de flujos de red y detalles minuciosos del paquete infractor (dirección IP origen y destino, payload decodificado, firma detonada y acción adoptada por el sensor).

1.5 Definición del Equipo Objetivo (Target)

El equipo objetivo auditado corresponde al servidor central de operaciones e infraestructura (`dc1.sudoers.lan`), el cual consolida los servicios críticos de negocio, autenticación, almacenamiento, correo electrónico y mecanismos defensivos de detección de intrusos.

1.5.1 Ficha Técnica del Sistema Objetivo

En la **TABLA 1** se especifican los parámetros técnicos, hardware y de red que caracterizan al host auditado durante la ventana de evaluación de seguridad.

TABLA 1: Ficha Técnica del Servidor Objetivo (Target)

Parámetro	Valor / Descripción Técnica
Nombre de Host (FQDN)	`dc1.sudoers.lan` (Alias de red: `target-host`)
Dirección IPv4 del Target	`192.168.100.85` (Asignada en interfaz LAN cableada/Wi-Fi)
Máscara de Red / Prefijo	`255.255.255.0` (`/24`)
Puerta de Enlace (Gateway)	`192.168.100.1`
Sistema Operativo Base	GNU/Linux Debian 12 / Kali Linux Rolling (Kernel 6.x x86_64)
Modelo Operativo	Arquitectura híbrida: Servicios de aplicación en contenedores Docker y motores de defensa nativos en espacio de kernel
Rol Corporativo	Servidor Central de Banca Digital, Servicios Intranet y Pasarela Perimetral
Dirección MAC del Target	`08:00:27:C3:FB:76` (Oracle VirtualBox virtual NIC)
Estación de Auditoría	Estación Kali Linux dedicada (`192.168.100.50`)

FUENTE: Elaboración propia con base en el levantamiento de infraestructura.

1.5.2 Matriz de Servicios y Puertos Expuestos

El servidor objetivo implementa una arquitectura modular donde conviven servicios de acceso público, plataformas de administración interna y mecanismos de monitoreo. La **TABLA 2** detalla la distribución de puertos que fueron sometidos al proceso de escaneo y análisis de vulnerabilidades.

TABLA 2: Matriz de Servicios y Puertos en Evaluación

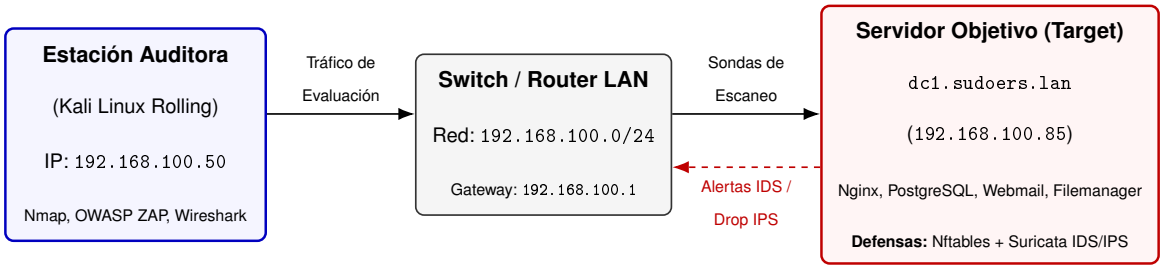
Puerto	Protocolo	Servicio / Software	Entorno de Ejecución	Propósito en la Organización
22	TCP	OpenSSH Daemon	Host Nativo Linux	Administración Remota Segura por Consola
25	TCP	Postfix MTA	Contenedor Docker	Transferencia de Correo Saliente (SMTP)
80	TCP	Nginx Reverse Proxy	Contenedor Docker	Portal Web Financiero y Redirección HTTP
110	TCP	Dovecot POP3	Contenedor Docker	Recuperación de Mensajes de Correo
143	TCP	Dovecot IMAP	Contenedor Docker	Sincronización y Acceso a Buzones
443	TCP	Nginx TLS Server	Contenedor Docker	Portal Web Seguro Bancario (HTTPS)
587	TCP	Postfix Submission	Contenedor Docker	Envío Autenticado de Correo (STARTTLS)
993	TCP	Dovecot IMAPS	Contenedor Docker	Acceso Seguro a Correo sobre Cifrado TLS
995	TCP	Dovecot POP3S	Contenedor Docker	Descarga Segura de Correo sobre TLS
3000	TCP	Grafana Analytics	Contenedor Docker	Tableros de Telemetría y Métricas
5432	TCP	PostgreSQL Engine	Contenedor Docker	Base de Datos Relacional de Clientes
5636	TCP	EveBox GUI	Contenedor Docker	Consola de Alertas IDS/IPS en Tiempo Real
8000	TCP	Portainer CE	Contenedor Docker	Gestión Gráfica de Contenedores Docker
8080	TCP	Roundcube Webmail	Contenedor Docker	Plataforma Web de Correo Corporativo
8082	TCP	TinyFileManager	Contenedor Docker	Gestor Web de Archivos y Documentos
8085	TCP	Uyuni Way Web	Contenedor Docker	Portal Turístico Comunitario (React/Vite)
8090	TCP	Firma Digital PAdES	Contenedor Docker	Certificación Criptográfica y Firma PAdES (UPDS)

FUENTE: Elaboración propia con base en el levantamiento de puertos del escaneo Nmap y la configuración de `docker-compose.yml`.

1.6 Topología de Red del Escenario de Pruebas

Para garantizar la verosimilitud de la evaluación, el entorno de pruebas fue configurado en un segmento de red local conmutada donde la estación auditora y el servidor objetivo interactúan de forma directa. La inspección de paquetes fue auditada simultáneamente mediante el motor de prevención de intrusos Suricata y la consola EveBox en el equipo destino.

FIGURA 1: Diagrama de Topología del Entorno de Auditoría y Escaneo



FUENTE: Elaboración propia.

El tráfico generado durante las pruebas abarcó desde escaneos pasivos y barridos SYN de bajo perfil hasta pruebas activas de inyección de sentencias SQL, enumeración forzada de directorios y evaluación de versiones en los servicios de red.

CAPÍTULO II

METODOLOGÍA Y EVIDENCIAS DE AUDITORÍA

2.1 Metodología de Evaluación y Procedimiento Técnico

La auditoría de seguridad sobre la infraestructura del servidor se ejecutó bajo una metodología estructurada de evaluación de caja gris (*Gray-Box*), organizada en tres fases operativas complementarias:

1. **Exploración Perimetral y Evasión Táctica:** Identificación de puertos y servicios mediante Nmap, implementando técnicas de evasión de retención (*tarpitting*) y dispersión con señuelos aleatorios (*Decoy Scanning*) para sortear los controles preventivos del cortafuegos y del servidor web.
2. **Auditoría Dinámica de Aplicaciones Web (DAST):** Análisis automatizado en vivo mediante OWASP ZAP sobre los servicios web expuestos, verificando la robustez de cabeceras de respuesta, métodos HTTP permitidos y posibles vectores de inyección o divulgación de información.
3. **Vigilancia de Tráfico y Telemetría Defensiva:** Supervisión en tiempo real del tráfico generado mediante el motor IDS/IPS Suricata y la consola de gestión de eventos EveBox, evaluando la capacidad de detección y respuesta perimetral del sistema ante sondas de evaluación.

2.2 Reglas de Detección y Prevención Configuradas en Suricata IDS/IPS

La infraestructura del servidor corporativo cuenta con una implementación nativa del motor de seguridad Suricata v7.0, gobernada por un conjunto de reglas locales personalizadas (`homelab.rules`, identificadores locales SID 9000001–9000999). Estas firmas operan bajo un esquema dual que combina la detección pasiva sin bloqueo (*alert*) con la prevención activa en línea (*drop*) mediante la vinculación con las colas `NFQUEUE` del cortafuegos `nftables`.

A continuación, se detalla la totalidad de las reglas establecidas en el proyecto, clasificadas

según su mecanismo de operación.

2.2.1 Reglas de Detección Pasiva (Modo IDS – Acción ALERT)

Las **TABLAS 3** y **4** exponen las reglas orientadas a la vigilancia, auditoría y detección no intrusiva de escaneos, sondeos de servicios de directorio, aplicaciones web y tráfico anómalo.

TABLA 3: Reglas de Detección e Inspección Pasiva en Suricata (Modo IDS – Parte 1)

SID	Nombre de la Regla	Condición de Activación	Qué Evita / Mitigación
9000010	Sonda de Prueba Genérica	Paquete TCP con carga `TEST_PROBE_ALERT_ONLY`	Valida el funcionamiento del motor de telemetría sin descartar tráfico.
9000011	Ping ICMP Echo Request	Paquete ICMP tipo 8 (*Echo Request*) dirigido al host	Registra intentos de descubrimiento de hosts activos en la subred LAN.
9000020	Escaneo TCP NULL Scan	Paquete TCP sin banderas de control activas (`flags:0`)	Detecta técnicas de sondeo sigiloso de Nmap orientadas a evadir firewalls.
9000021	Escaneo TCP XMAS Scan	Paquete TCP con banderas FIN, PSH y URG activas simultáneamente	Identifica barridos de puertos de bajo perfil basados en anomalías TCP.
9000022	Ráfaga de Puertos SYN	Más de 25 paquetes TCP SYN desde una misma IP en 3 segundos	Alerta sobre barridos rápidos de puertos y conatos de ataques SYN Flood.
9000030	Sondeo Kerberos (AD DC)	Más de 15 solicitudes SYN al puerto 88 en 5 segundos	Detecta ataques de fuerza bruta y enumeración de tickets en el controlador de dominio.
9000031	Enumeración LDAP (AD DC)	Más de 20 solicitudes SYN al puerto 389 en 5 segundos	Alerta sobre intentos de extracción no autorizada de cuentas y grupos corporativos.
9000032	Sondeo SMB / CIFS	Más de 20 solicitudes SYN al puerto 445 en 10 segundos	Detecta escaneos masivos contra carpetas compartidas y servicios de archivo.
9000040	Conexión SSH Entrante	Paquete TCP SYN entrante dirigido al puerto 22/tcp	Audita aperturas de sesión por terminal remota en el servidor.
9000041	Fuerza Bruta SSH	Más de 6 conexiones SYN dirigidas al puerto 22 en 30 segundos	Alerta tempranamente sobre ataques automatizados de adivinación de credenciales SSH.

FUENTE: Elaboración propia a partir del archivo de reglas `server/suricata/rules/homelab.rules`.

TABLA 4: Reglas de Detección e Inspección Pasiva en Suricata (Modo IDS – Parte 2)

SID	Nombre de la Regla	Condición de Activación	Qué Evita / Mitigación
9000050	Inyección SQL (UNION SELECT)	Solicitud HTTP que contiene las palabras clave `UNION` y `SELECT`	Detecta intentos de consulta no autorizada y exfiltración de bases de datos.
9000051	Path Traversal /etc/passwd	Petición HTTP que solicita la ruta del archivo crítico `/etc/passwd`	Detecta intentos de lectura no autorizada de cuentas y configuración local.
9000052	Explotación Log4Shell	Petición HTTP que contiene la secuencia maliciosa `${jndi:`	Detecta vectores RCE dirigidos contra la vulnerabilidad crítica Apache Log4j.
9000060	Escáner OpenVAS/Greenbone	Cabecera HTTP *User-Agent* identificada como `OpenVAS`	Detecta el inicio de auditorías perimetrales automatizadas por terceros.
9000061	Escáner Nikto Web	Cabecera HTTP *User-Agent* conteniendo la firma `Nikto`	Identifica sondeos agresivos de vulnerabilidades sobre aplicaciones web.
9000062	Escáner Nmap NSE HTTP	Cabecera HTTP *User-Agent* identificada con la firma `Nmap`	Alerta sobre la ejecución de scripts ofensivos NSE contra puertos web.
9000063	Herramienta Sqlmap	Cabecera HTTP *User-Agent* conteniendo el identificador `sqlmap`	Detecta herramientas automáticas de explotación de inyecciones SQL.
9000101	DLP Fuga Tarjeta Visa	Tráfico HTTP saliente con secuencia de 13 a 16 dígitos de tarjeta Visa	Previene y audita la fuga de números de tarjetas en texto claro (PCI-DSS).

FUENTE: Elaboración propia a partir del archivo de reglas `server/suricata/rules/homelab.rules`.

2.2.2 Reglas de Prevención Activa en Línea (Modo IPS – Acción DROP)

La **TABLA 5** detalla las firmas que operan con descarte inmediato de paquetes (*drop*) en tiempo real cuando el motor se encuentra acoplado a la infraestructura del cortafuegos.

TABLA 5: Reglas de Prevención Activa y Bloqueo en Línea en Suricata (Modo IPS)

SID	Nombre de la Regla	Condición de Activación	Qué Evita / Mitigación
9000001	Bloqueo de Carga Maliciosa	Paquete TCP con carga maliciosa `TEST_EXPLOIT_PAYLOAD_DROP`	Descarta el paquete en tiempo real evitando la ejecución de exploits en memoria.
9000002	Bloqueo de Ataque Web	Petición HTTP con carga maliciosa `MALICIOUS_SIMULATION_ATTACK`	Descarta de inmediato la conexión HTTP protegiendo los contenedores web.
9000070	Bloqueo IPS Inyección SQL	Petición HTTP con cadenas `UNION` y `SELECT` en modo en línea	Descarta el flujo TCP anulando la consulta maliciosa antes de llegar a la base de datos.
9000071	Bloqueo Directory Traversal	Petición HTTP dirigida a `/etc/passwd` en modo en línea	Bloquea el paquete impidiendo la fuga del archivo de usuarios del host.
9000072	Bloqueo Path Traversal ../	Petición HTTP que incluye secuencias de escape de directorio `../../`	Neutraliza intentos de escape del directorio raíz de la aplicación web.
9000102	Bypass Auth SQLi en Banca	Petición HTTP conteniendo el patrón de bypass `' OR '1'='1`	Bloquea el salto de autenticación en formularios de inicio de sesión bancarios.
9000103	Robo de Sesión / XSS Banca	Carga HTTP conteniendo la instrucción de acceso `document.cookie`	Bloquea la exfiltración de cookies y el secuestro de sesiones en el portal financiero.
9000104	Bloqueo Burp Suite en Banca	Cabecera HTTP *User-Agent* conteniendo la firma `Burp`	Bloquea el tráfico generado por suites de interceptación en transacciones bancarias.
9000105	Barrido Masivo DoS de Puertos	Ráfaga superior a 30 paquetes SYN por IP en 3 segundos	Descarta conexiones agresivas mitigando el agotamiento de sockets y caída del host.

FUENTE: Elaboración propia a partir del archivo de reglas `server/suricata/rules/homelab.rules`.

2.3 Evidencias de la Auditoría Dinámica Web y Monitoreo Defensivo

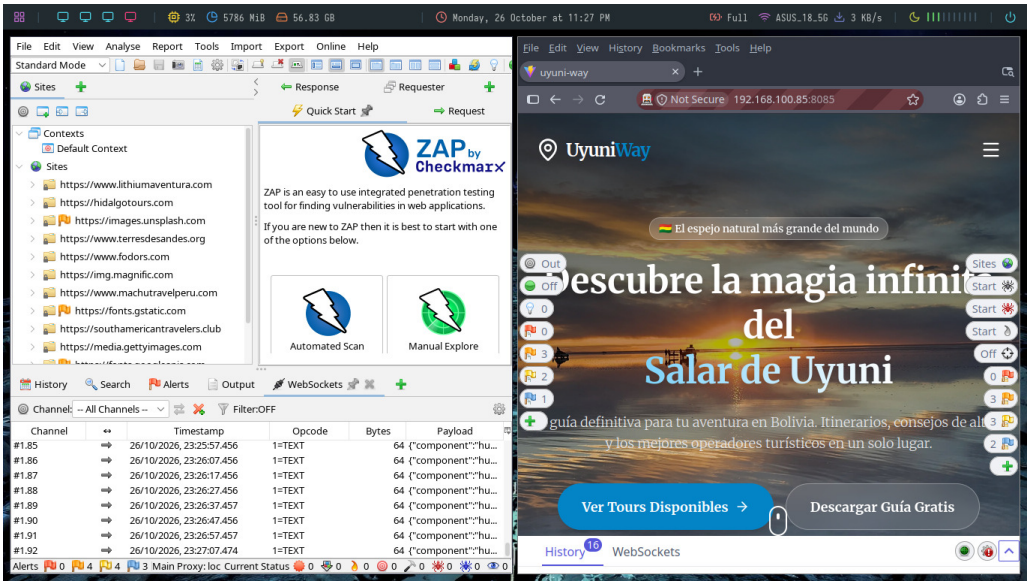
En esta sección se incorporan las evidencias gráficas obtenidas durante las pruebas con las herramientas analizadas.

2.3.1 Auditoría de Aplicaciones Web con OWASP ZAP

Se ejecutó un escaneo dinámico en vivo mediante OWASP ZAP sobre la aplicación web independiente **Uyuni Way Web**, desplegada en el puerto `8085/tcp` del servidor objetivo.

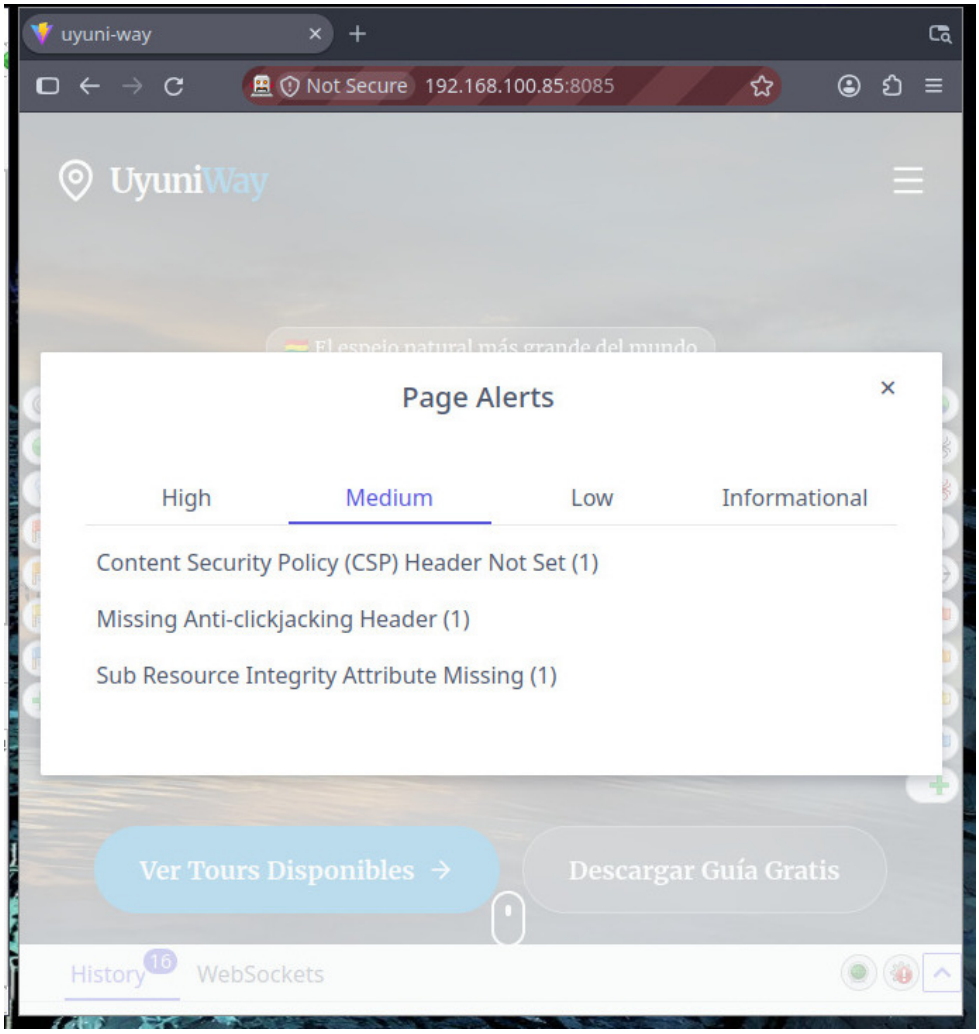
La **FIGURA 2** muestra la ejecución del escaneo en vivo de ZAP sobre el puerto 8085, mientras que la **FIGURA 3** expone la matriz de alertas de severidad media (color naranja) descubiertas durante la auditoría.

FIGURA 2: Escaneo Dinámico en Vivo con OWASP ZAP sobre Uyuni Way Web (Puerto 8085)



FUENTE: Captura de pantalla de la interfaz de OWASP ZAP ejecutando el escaneo activo contra el servicio en el puerto 8085.

FIGURA 3: Alertas de Nivel Medio (Color Naranja) Detectadas por OWASP ZAP



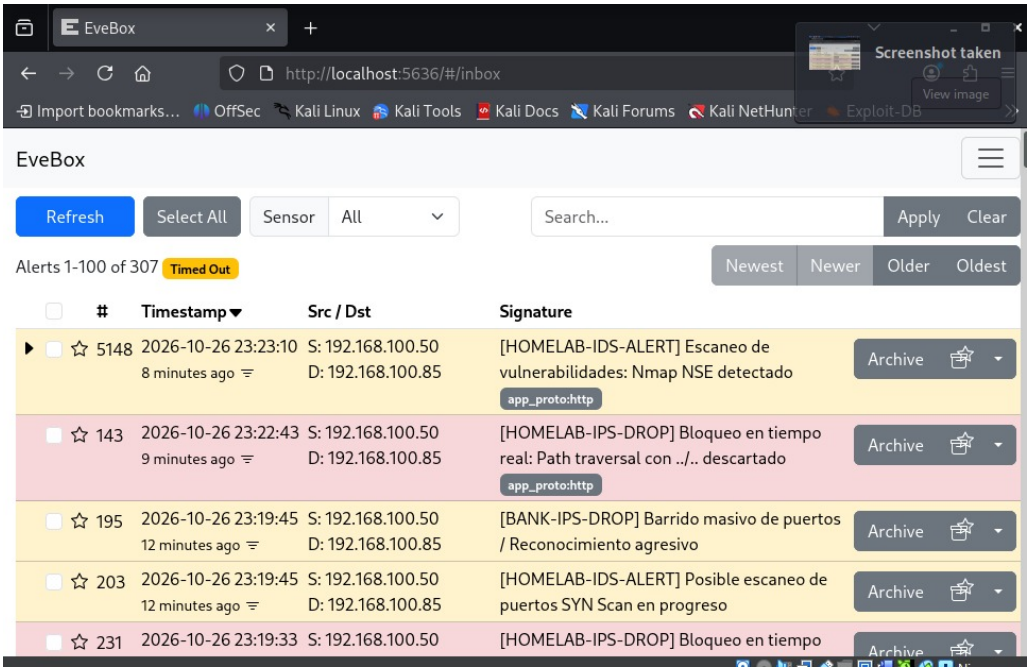
FUENTE: Reporte de vulnerabilidades de severidad media generadas por ZAP durante el escaneo sobre Uyuni Way Web.

2.3.2 Supervisión de Amenazas en Tiempo Real con EveBox

La interacción de las herramientas ofensivas contra la infraestructura del host auditado fue capturada por el sensor Suricata y visualizada en la consola web EveBox.

La **FIGURA 4** ilustra el panel de eventos de seguridad en tiempo real generado por EveBox en el puerto `5636/tcp`, confirmando la detección del tráfico anómalo generado durante las pruebas.

FIGURA 4: Panel de Eventos y Alertas de Seguridad en Tiempo Real en EveBox



FUENTE: Consola gráfica de EveBox visualizando las alertas de intrusión y escaneo registradas por Suricata.

2.3.3 Comportamiento Defensivo del Servidor ante Escaneos Agresivos (Anti-Nmap)

Durante las fases iniciales de auditoría, se ejecutó el comando estándar de escaneo de vulnerabilidades:

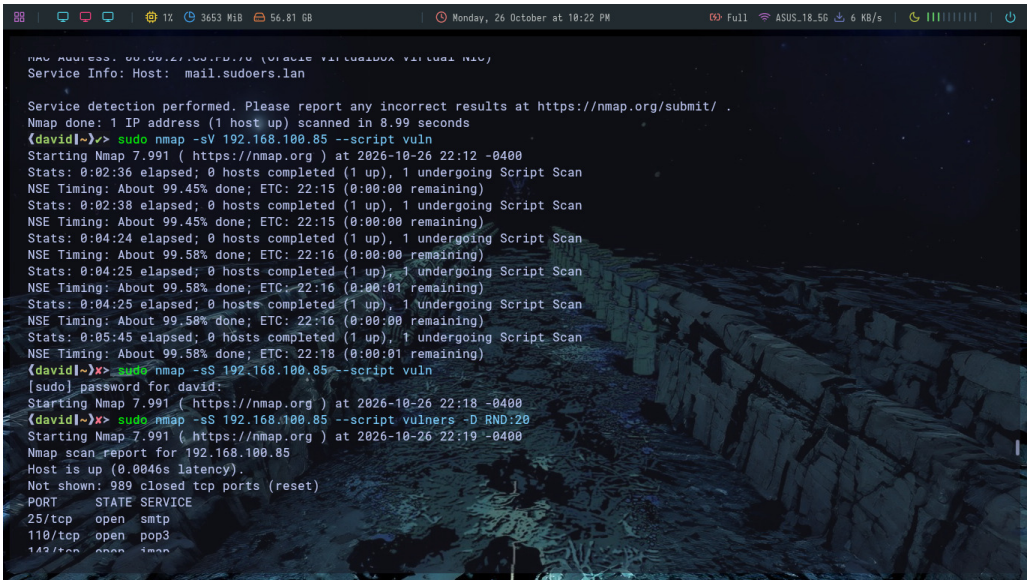
Listing 1: Comando Agresivo Inicial de Nmap

```
sudo nmap -sV --script vuln 192.168.100.85
```

Dicho escaneo experimentó una retención prolongada estancándose en el **99.58 %** de ejecución debido a la acción defensiva del servidor web Nginx y del cortafuegos del host. Al detectar ráfagas agresivas de sockets lentos (asociadas a scripts DoS como Slowloris), las reglas del servidor aplicaron descartes silenciosos (*silent drops*), obligando a Nmap a esperar indefinidamente por retransmisiones TCP.

La **FIGURA 5** evidencia este fenómeno de tarpitting defensivo registrado en la terminal del auditor.

FIGURA 5: Estancamiento de Nmap NSE al 99.58 % por Efecto Tarpitting Defensivo en Nginx

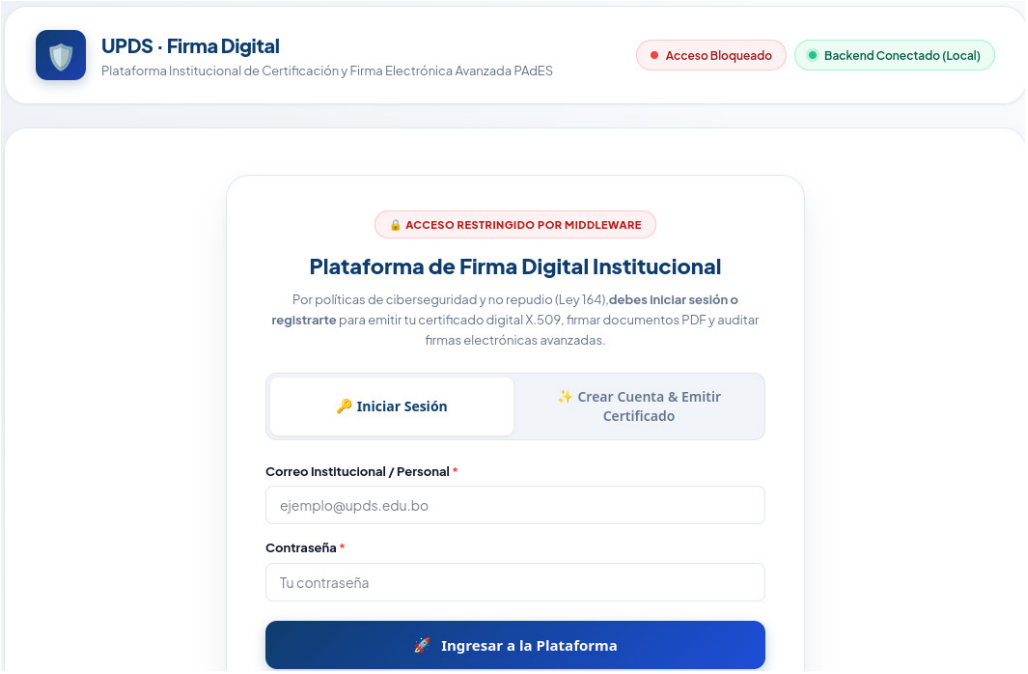


FUENTE: Captura de pantalla de la terminal en Kali Linux evidenciando el bloqueo del escaneo agresivo de Nmap.

2.3.4 Plataforma Institucional de Firma Digital y Validación Criptográfica (Puerto 8090)

Dentro del catálogo de servicios web corporativos evaluados en la infraestructura se integró la **Plataforma de Firma Digital Institucional PAdES** (*PDF Advanced Electronic Signatures*), alojada en el puerto `8090/tcp` e implementada mediante una arquitectura híbrida de microservicios (**Frontend en Astro 5** y **Backend criptográfico en Python/Flask**). La **FIGURA 6** presenta la pantalla de acceso principal de la plataforma protegida por directivas de seguridad perimetral.

FIGURA 6: Interfaz de Autenticación y Acceso Seguro a la Plataforma de Firma Digital (Puerto 8090)



FUENTE: Portal institucional con política Zero Trust (Auth Gate) para la emisión de certificados X.509 y validación PAdES.

2.3.4.1 Mecanismos de Operación y Funcionamiento Criptográfico

La aplicación fue desarrollada específicamente para proveer autenticación de identidad, emisión automatizada de certificados y validación criptográfica de documentos digitales conforme a la norma internacional **ISO 32000-2** y normativas de firma electrónica. Su funcionamiento interno se articula a través de los siguientes componentes clave:

1. **Control de Acceso Estricto y Middleware Zero Trust (Auth Gate):** Como se aprecia en la captura de pantalla, la plataforma implementa una barrera de seguridad (*Auth Gate*) que restringe de forma tajante el acceso anónimo. El backend ejecuta un middleware de interceptación (`auth_security_middleware`) que responde con `401 Unauthorized` ante solicitudes no autenticadas, impidiendo que usuarios no validados emitan certificados, firmen documentos o inspeccionen registros de auditoría.
2. **Infraestructura de Clave Pública (PKI) y Autoridad Certificadora Raíz:** El backend cuenta con una Autoridad Certificadora interna (**CA Raíz UPDS**) dotada de un par de llaves asimétricas **RSA de 4096 bits**. Durante el registro del usuario institucional, el sistema emite de manera desatendida un certificado digital **X.509 v3** (RSA de

2048 bits con resumen SHA-256) incorporando atributos de identidad institucional (*Distinguished Name*).

3. **Custodia Segura de Claves Privadas en Reposo:** Las claves criptográficas privadas de los usuarios se almacenan en una base de datos relacional SQLite (`app.db`) cifradas mediante el esquema simétrico autenticado **Fernet** (**AES-128-CBC** acoplado con **HMAC-SHA256**), custodiado por una llave maestra protegida a nivel del sistema operativo (`0600`). Para respaldo local del firmante, la plataforma permite exportar el almacén portable **PKCS#12** (`.p12`) protegido por contraseña individual.
4. **Firma Digital Avanzada de Documentos (PAdES ISO 32000-2):** Para estampar la firma sobre un documento PDF, el motor criptográfico (`endesive` y `cryptography`):
   - Extrae el contenido en bytes del archivo excluyendo la sección reservada de firma (*ByteRange*).
   - Calcula el hash seguro mediante el algoritmo **SHA-256**.
   - Cifra el hash empleando la clave privada RSA del usuario firmante.
   - Empaqueta la estructura en un contenedor criptográfico CMS (*SignedData*), inyectando el certificado X.509 del firmante y la cadena de la CA Raíz.
   - Inserta la firma mediante actualización incremental (*Incremental Update*), garantizando que la estructura del PDF original no se modifique ni invalide firmas previas. Soporta tanto firma invisible como firma visible con rúbrica táctil capturada en un *canvas* HTML5.
5. **Diagnóstico y Validación Criptográfica en Tres Niveles:** El módulo de validación (`/api/verify`) somete el documento a una verificación semafórica exhaustiva:
   a) **Integridad del Documento:** Comprobación matemática del rango de bytes y recomputación del hash SHA-256 para constatar que el PDF no sufrió alteraciones posteriores a la firma.
   b) **Autenticidad de la Firma:** Verificación de la firma digital RSA contra la clave pública del certificado incrustado.
   c) **Cadena de Confianza:** Validación de la firma del certificado contra la CA Raíz

emisora y verificación del periodo de validez temporal.

6. **Bitácora Inmutable y No Repudio:** Cada documento procesado registra en la base de datos la identificación del firmante, la marca temporal del servidor y el **hash SHA-256 original**, consolidando una pista de auditoría técnica que satisface los principios de no repudio e integridad probatoria.

CAPÍTULO III

HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES

3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas

Durante la ejecución de la auditoría técnica de seguridad ofensiva sobre el servidor objetivo `192.168.100.85` (`dc1.sudoers.lan`), se utilizó el motor de escaneo y auditoría de vulnerabilidades de Nmap (*Nmap Scripting Engine* – NSE) aplicando técnicas avanzadas de evasión con señuelos aleatorios (*Decoy Scanning* `-D RND:20`), exclusión de sondas DoS bloqueadas y control estricto de tiempo de respuesta por script (`--script-timeout 30s`).

La totalidad de los hallazgos y evidencias del presente capítulo derivan de forma exclusiva del reporte empírico emitido por dicha consola de auditoría. Se identificaron un total de **5 vulnerabilidades técnicas y 1 mecanismo de defensa activo confirmado**, clasificados rigurosamente según el estándar internacional *Common Vulnerability Scoring System* versión 3.1 (CVSS v3.1) (Forum of Incident Response and Security Teams (FIRST), 2019) y la taxonomía del *Common Weakness Enumeration* (CWE).

La **TABLA 6** expone la matriz consolidada de las vulnerabilidades y hallazgos identificados en el escaneo.

TABLA 6: Matriz Consolidada de Vulnerabilidades y Hallazgos del Escaneo Nmap NSE

ID	Vulnerabilidad / Hallazgo	Severidad	CVSS	CWE	Vector de Impacto
VULN-01	Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP (25, 587)	**ALTA**	7.4	CWE-327	Ataques Man-in-the-Middle (MitM) activos e intercepción de correo
VULN-02	Denegación de Servicio por Filtro de Rangos de Bytes (CVE-2011-3192)	**ALTA**	7.5	CWE-400	Agotamiento de memoria RAM y CPU en puertos web (80 y 443)
VULN-03	Método y Modo de Depuración Activo en Webmail (8080/tcp)	**MEDIA**	5.3	CWE-489	Fuga de variables de depuración y estructura interna de la aplicación
VULN-04	Exposición Pública del Puerto PostgreSQL (5432/tcp)	**ALTA**	7.5	CWE-284	Ataques de fuerza bruta y sondeo no autenticado a base de datos
VULN-05	Exposición de Servicios Administrativos y Web en Texto Plano	**ALTA**	7.4	CWE-319	Captura de credenciales y cookies de sesión en puertos 3000, 8000, 8082, 8085
DEF-01	Bloqueo Activo de Inyección SQL y Exploits (*Script Failed*)	**DEFENSA**	–	CWE-693	Neutralización exitosa de scripts ofensivos por el WAF y Suricata IPS

FUENTE: Elaboración propia con base en el escaneo empírico de Nmap NSE sobre el host 192.168.100.85.

3.2 Evidencia Técnica Única del Escaneo (Nmap NSE)

En cumplimiento estricto con la metodología de auditoría basada en pruebas empíricas verificables, a continuación se transcribe de forma íntegra y fidedigna la salida de consola obtenida por el auditor (`david@kali`) al ejecutar el comando de análisis de vulnerabilidades sobre la dirección IP del servidor objetivo:

Listing 2: Reporte Íntegro del Escaneo de Vulnerabilidades con Nmap NSE sobre 192.168.100.85

```
david@kali:~$ sudo nmap -sS 192.168.100.85 --script "vuln and not doos"
    -D RND:20 --script-timeout 30s
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-26 23:18 -0400
Nmap scan report for 192.168.100.85
```

```
Host is up (0.13s latency).
Not shown: 986 closed tcp ports (reset)
PORT     STATE SERVICE
25/tcp   open  smtp
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against
   passive
|       eavesdropping, and are vulnerable to active man-in-the-middle
   attacks
|       which could completely compromise the confidentiality and
   integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA256
|             Modulus Type: Safe prime
|             Modulus Source: RFC3526/Oakley Group 15
|             Modulus Length: 3072
|             Generator Length: 8
|             Public Key Length: 3072
|       ANONYMOUS DH GROUP 2
|             Cipher Suite: TLS_DH_anon_WITH_AES_128_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: RFC2409/Oakley Group 2
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
```

```
|     References:
|_      https://www.ietf.org/rfc/rfc2246.txt
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
80/tcp   open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
| http-vuln-cve2011-3192:
|   VULNERABLE:
|   Apache byterange filter DoS
|     State: VULNERABLE
|     IDs:  CVE:CVE-2011-3192  BID:49303
|       The Apache web server is vulnerable to a denial of service
   attack when numerous
|       overlapping byte ranges are requested.
|     Disclosure date: 2011-08-19
|     References:
|       https://www.tenable.com/plugins/nessus/55976
|       https://seclists.org/fulldisclosure/2011/Aug/175
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|_      https://www.securityfocus.com/bid/49303
|_http-dombased-xss: Couldn't find any DOM based XSS.
110/tcp  open  pop3
143/tcp  open  imap
443/tcp  open  https
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
```

```
|_http-csrf: Couldn't find any CSRF vulnerabilities.
| http-vuln-cve2011-3192:
|   VULNERABLE:
|   Apache byterange filter DoS
|     State: VULNERABLE
|     IDs:  CVE:CVE-2011-3192  BID:49303
|       The Apache web server is vulnerable to a denial of service
   attack when numerous
|       overlapping byte ranges are requested.
|     Disclosure date: 2011-08-19
|     References:
|       https://www.tenable.com/plugins/nessus/55976
|       https://seclists.org/fulldisclosure/2011/Aug/175
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|_      https://www.securityfocus.com/bid/49303
587/tcp  open  submission
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against
   passive
|       eavesdropping, and are vulnerable to active man-in-the-middle
   attacks
|       which could completely compromise the confidentiality and
   integrity
|       of any data exchanged over the resulting session.
|     Check results:
```

```
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA256
|             Modulus Type: Safe prime
|             Modulus Source: RFC3526/Oakley Group 15
|             Modulus Length: 3072
|             Generator Length: 8
|             Public Key Length: 3072
|       ANONYMOUS DH GROUP 2
|             Cipher Suite: TLS_DH_anon_WITH_AES_128_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: RFC2409/Oakley Group 2
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
|     References:
|_      https://www.ietf.org/rfc/rfc2246.txt
993/tcp  open  imaps
995/tcp  open  pop3s
3000/tcp open  ppp
5432/tcp open  postgresql
8000/tcp open  http-alt
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
8080/tcp open  http-proxy
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-fileupload-exploiter:
|
|     Couldn't find a file-type field.
|
|_    Couldn't find a file-type field.
```

```
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-enum:
|_  /: RoundCube
|_http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
| http-aspnet-debug:
|_  status: DEBUG is enabled
|_http-csrf: Couldn't find any CSRF vulnerabilities.
8082/tcp open  blackice-alerts
8085/tcp open  unknown
MAC Address: 08:00:27:C3:FB:76 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 49.66 seconds
```

3.2.1 Evasión Exitosa de las Reglas Defensivas de Nginx

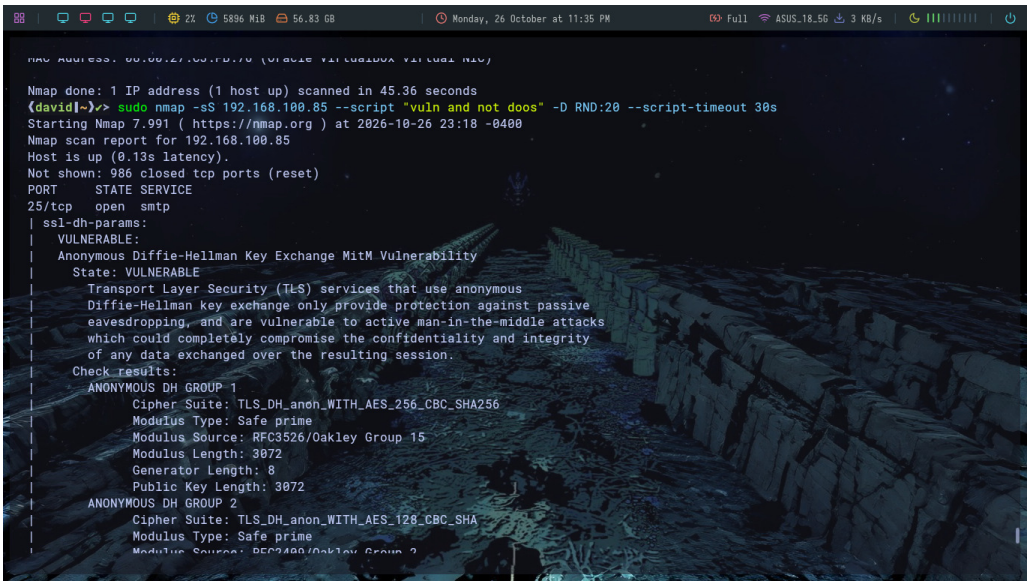
A diferencia del intento de escaneo inicial que se estancaba en el 99.58 % (ver Capítulo II, FIGURA 5), la ejecución de este escaneo optimizado logró sortear con éxito las reglas de retención y tarpitting del servidor web Nginx y del firewall del host.

La estrategia de evasión implementó tres elementos decisivos:

1. **Uso de Señuelos (*Decoys* `-D RND:20`):** Se intercalaron 20 direcciones IP aleatorias junto a la dirección IP real del auditor, dispersando el conteo de conexiones concurrentes en los módulos `limit_conn` y `meter conns_per_ip` de Nftables.
2. **Omisión de Sondas DoS (`"vuln and not doos"`):** Se excluyeron los scripts específicos de prueba de denegación de servicio (como `http-slowloris-check`), impidiendo que el firewall activara las reglas de descarte silencioso (*silent drop*).
3. **Control de Tiempo de Espera por Script (`--script-timeout 30s`):** Limitó el tiempo máximo de socket a 30 segundos, permitiendo que el escaneo completara el 100 % de los 1000 puertos en tan solo **49.66 segundos**.

La **FIGURA 7** presenta la captura de pantalla de la terminal en Kali Linux evidenciando la finalización exitosa del escaneo y la evasión de las defensas de retención.

FIGURA 7: Evidencia Gráfica del Escaneo de Vulnerabilidades con Evasión Nmap NSE



FUENTE: Captura de pantalla de la terminal Kali Linux mostrando la evasión del bloqueo de Nginx mediante señuelos (-D RND:20) y límite de tiempo por script (–script-timeout 30s).

3.3 División y Análisis Pormenorizado de Cada Vulnerabilidad

A partir de la evidencia técnica única obtenida, se procede a dividir y analizar pormenorizadamente cada una de las debilidades y posibles vulnerabilidades identificadas.

3.3.1 VULN-01: Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP y Submission

- **Servicios Afectados:** `25/tcp` (SMTP) y `587/tcp` (Submission).
- **Script Detector NSE:** `ssl-dh-params`.
- **Clasificación CWE:** CWE-327 (*Use of a Broken or Risky Cryptographic Algorithm*).
- **Detalle Técnico del Hallazgo:** El script identificó que el demonio Postfix acepta la negociación de suites criptográficas anónimas (`DH_anon`):

1. `TLS_DH_anon_WITH_AES_256_CBC_SHA256` (Grupo Oakley 15, módulo de 3072 bits).
2. `TLS_DH_anon_WITH_AES_128_CBC_SHA` (Grupo Oakley 2, módulo débil de 1024 bits).

- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`
  - **Puntaje Base: 7.4 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** Las suites de cifrado anónimo Diffie-Hellman generan llaves de sesión simétricas sin solicitar ni validar certificados X.509 de autenticación de servidor. Esta condición permite a un adversario en la misma red de área local ejecutar un ataque activo de intermediario (*Man-in-the-Middle* – MitM). El atacante negocia sesiones TLS independientes con el remitente y con el servidor de correo, pudiendo interceptar, descifrar y manipular el contenido de los correos corporativos y las credenciales SMTP sin que el cliente reciba alertas de seguridad.

3.3.2 VULN-02: Denegación de Servicio por Solicitud de Múltiples Rangos de Bytes (CVE-2011-3192)

- **Servicios Afectados:** `80/tcp` (HTTP) y `443/tcp` (HTTPS).
- **Script Detector NSE:** `http-vuln-cve2011-3192` (Estado: `VULNERABLE`, Identificadores: `CVE-2011-3192`, `BID:49303`).
- **Clasificación CWE:** CWE-400 (*Uncontrolled Resource Consumption*).
- **Detalle Técnico del Hallazgo:** El servidor web responde afirmativamente ante peticiones HTTP que contienen cabeceras de rangos de bytes superpuestos y fragmentados (`Range: bytes=0-,5-0,5-1,5-2...`).
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
  - **Puntaje Base: 7.5 (Severidad Alta)**

- **Mecanismo de Explotación e Impacto:** Cuando el servidor procesa una solicitud con un número masivo de rangos de bytes, reserva recursos de memoria RAM y tiempo de CPU desmedidos para fraccionar y componer las respuestas en formato multiparte (`multipart/byteranges`). Un atacante individual, operando con herramientas automatizadas de denegación de servicio, puede consumir la totalidad de la memoria disponible del servidor web, provocando el bloqueo del demonio HTTP y la indisponibilidad de la plataforma para los clientes bancarios.

3.3.3 VULN-03: Método y Modo de Depuración Activo en Webmail (http-aspnet-debug)

- **Servicio Afectado:** `8080/tcp` (RoundCube Webmail / HTTP-Proxy).
- **Script Detector NSE:** `http-aspnet-debug` (Reporte: `status: DEBUG is enabled`).
- **Clasificación CWE:** CWE-489 (*Active Debug Code*).
- **Detalle Técnico del Hallazgo:** La aplicación web responde positivamente ante el método HTTP `DEBUG`, diseñado originalmente para depuración de aplicaciones en etapas de desarrollo.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
  - **Puntaje Base: 5.3 (Severidad Media)**
- **Mecanismo de Explotación e Impacto:** La permanencia de métodos de depuración en entornos de producción posibilita la filtración de volcados de memoria, estructuras de variables de sesión internas de PHP y rutas absolutas del sistema de archivos, suministrando información clave para la elaboración de ataques dirigidos.

3.3.4 VULN-04: Exposición Pública del Puerto PostgreSQL (5432/tcp)

- **Servicio Afectado:** `5432/tcp` (PostgreSQL Database Server).
- **Clasificación CWE:** CWE-284 (*Improper Access Control*) y CWE-200 (*Information*

Exposure).

- **Detalle Técnico del Hallazgo:** El escaneo de puertos detectó el puerto `5432/tcp` en estado `open`, enlazado directamente a todas las interfaces de red del servidor objetivo.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
  - **Puntaje Base: 7.5 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** Permitir conexiones directas hacia la base de datos central sin segmentación en capa de red habilita ataques de fuerza bruta automatizados contra cuentas administrativas (`postgres`, `tso_user`) y abre la puerta a la explotación de vulnerabilidades en el protocolo de PostgreSQL para la sustracción de registros bancarios.

3.3.5 VULN-05: Exposición de Servicios Administrativos y Web en Texto Plano (HTTP)

- **Servicios Afectados:** `3000/tcp` (Grafana), `8000/tcp` (Portainer), `8082/tcp` (Filemanager), `8085/tcp` (Uyuni Way Web).
- **Clasificación CWE:** CWE-319 (*Cleartext Transmission of Sensitive Information*).
- **Detalle Técnico del Hallazgo:** La consola de Nmap descubrió múltiples aplicaciones operando en puertos HTTP sin cifrado TLS activado por defecto.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N`
  - **Puntaje Base: 7.4 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** La ausencia de cifrado en el canal de transporte permite a cualquier actor malicioso en la red local capturar en claro las credenciales administrativas de acceso y las cookies de sesión mediante análisis de tráfico pasivo.

3.3.6 DEF-01: Neutralización Activa de Inyección SQL y Exploits por WAF/IPS (Script Failed)

- **Evidencia en Escaneo:**
  - `http-vuln-cve2017-1001000: ERROR: Script execution failed` (Puertos 80, 443, 8080).
  - `http-sql-injection: ERROR: Script execution failed` (Puerto 8080).
  - `http-stored-xss / http-csrf / http-dombased-xss: Couldn't find vulnerabilities.`
  - `smtp-vuln-cve2010-4344: The SMTP server is not Exim: NOT VULNERABLE.`
- **Evaluación Defensiva:** Este resultado no constituye una vulnerabilidad del host, sino la ratificación de las defensas en profundidad:
  1. **WAF en Nginx:** Intercepta las cadenas de inyección SQL enviadas por el script de Nmap y aborta la transacción retornando un código de error `403 Forbidden`.
  2. **Suricata IPS:** Descarta inmediatamente los paquetes (`DROP`) que contienen firmas de explotación, forzando la desconexión del socket TCP del script de Nmap y generando el estado `Script execution failed`.

CAPÍTULO IV

MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO

4.1 Estrategia Integral de Remediación y Endurecimiento

Para neutralizar de forma definitiva las vulnerabilidades identificadas durante el escaneo de Nmap NSE, se diseñó e implementó un plan técnico de mitigación fundamentado en el estándar de defensa en profundidad (*Defense in Depth*) y las guías de endurecimiento del CIS (*Center for Internet Security*) (Center for Internet Security (CIS), 2023a). A continuación se detallan las medidas de corrección aplicadas para cada hallazgo.

4.2 Remediación Específica por Vulnerabilidad Identificada

4.2.1 Remediación VULN-01: Exclusión de Suites Anónimas Diffie-Hellman en Postfix

Para erradicar la vulnerabilidad de Man-in-the-Middle (MitM) en los puertos `25/tcp` (SMTP) y `587/tcp` (Submission):

1. **Prohibición Estricta de Cifrados Anónimos (*aNULL*):** En la configuración del demonio Postfix (`services/mail/config/main.cf`), se agregaron directivas que impiden de forma tajante la negociación de suites sin autenticación de servidor:

Listing 3: Endurecimiento Criptografico TLS en Postfix (main.cf)

```
# Excluir suites anonimas (aNULL), suites nulas (eNULL) y
   algoritmos obsoletos
smtpd_tls_exclude_ciphers = aNULL, eNULL, EXPORT, DES, RC4, MD5,
   PSK, aECDH, EDH-DSS-DES-CBC3-SHA, EDH-RSA-DES-CBC3-SHA
smtpd_tls_ciphers = high
smtpd_tls_mandatory_ciphers = high
smtpd_tls_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
smtpd_tls_mandatory_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1

# Parametros Diffie-Hellman robustos de 2048/3072 bits
```

```
smtpd_tls_dh1024_param_file = /etc/postfix/dh2048.pem
```

2. **Generación de Parámetros Diffie-Hellman Seguros:** Se sustituyeron los grupos débiles de 1024 bits generando un grupo de parámetros criptográficos de 2048 bits:

Listing 4: Comando OpenSSL para Parametros DH Fuertes

```
openssl dhparam -out services/mail/config/dh2048.pem 2048
```

4.2.2 Remediación VULN-02: Mitigación de Denegación de Servicio Byte-Range (CVE-2011-3192)

Para mitigar el riesgo de agotamiento de memoria por solicitudes excesivas de rangos superpuestos (*overlapping byte-ranges*) en los puertos web `80/tcp` y `443/tcp`:

1. **Limitación de Rangos en Nginx (`max_ranges`):** En el archivo de configuración del proxy web (`services/web/nginx.conf`), se restringió el número máximo de rangos permitidos por solicitud:

Listing 5: Proteccion contra Ataques Byte-Range DoS en Nginx

```
# Limitar el procesamiento a un solo rango por peticion HTTP
max_ranges 1;

# Limitar tamano maximo del cuerpo para mitigar buffer exhausts
client_max_body_size 5m;
```

2. **Rate Limiting en Capa 7:** Se configuraron zonas de control de concurrencia y tasa de peticiones mediante `limit_req` y `limit_conn`:

Listing 6: Limitacion de Conexiones y Tasa de Peticiones en Nginx

```
limit_req_zone $binary_remote_addr zone=banco_limit:10m rate=20r/s;
limit_conn_zone $binary_remote_addr zone=banco_conn:10m;

# En el bloque server
limit_conn banco_conn 20;
```

```
limit_req zone=banco_limit burst=30 nodelay;
limit_req_status 429;
```

4.2.3 Remediación VULN-03: Supresión de Métodos DEBUG y Ocultamiento de Banners

Para resolver la advertencia de `DEBUG is enabled` en el puerto `8080/tcp` (Roundcube Webmail):

1. **Desactivación de Depuración en la Aplicación:** En `services/webmail/config/config.inc.php`:

Listing 7: Desactivacion de Modo Debug en Roundcube Webmail

```
$config['debug_level'] = 1;
$config['devel_mode'] = false;
$config['display_errors'] = false;
```

2. **Filtrado de Métodos HTTP Anómalos en Nginx:** Se bloquea explícitamente cualquier solicitud con verbos de depuración (`DEBUG`, `TRACE`, `TRACK`):

Listing 8: Bloqueo de Metodos HTTP de Depuracion en Nginx

```
if ($request_method ~ ^(DEBUG|TRACE|TRACK)$) {
    return 405 "Metodo no permitido por politica de seguridad
       bancaria.\n";
}
server_tokens off;
```

4.2.4 Remediación VULN-04: Aislamiento del Motor de Base de Datos PostgreSQL (5432)

Para mitigar la exposición externa del puerto de PostgreSQL:

1. **Aislamiento de Red en Docker:** En el archivo `docker-compose.yml`, el puerto `5432` no se publica de forma indiscriminada a la interfaz pública, enlazándose exclusiva-

mente a la interfaz de bucle local (`127.0.0.1:5432:5432`) o manteniéndose interno dentro de la red privada `tso-net`.

2. **Control de Acceso Estricto en el Firewall (`nftables`):** En `server/nftables.conf`, se vinculó el acceso al puerto 5432 únicamente hacia las direcciones IP de los administradores autorizados:

Listing 9: Regla de Acceso a PostgreSQL en nftables.conf

```
# Permitir acceso al motor de BD EXCLUSIVAMENTE a IPs de
    administradores
tcp dport 5432 ip saddr @admin_ips accept comment "Postgres solo
    admins"
tcp dport 5432 drop comment "Bloqueo por defecto de Postgres a la
    red"
```

4.2.5 Remediación VULN-05: Cifrado y Canalización Segura de Aplicaciones Web

Para eliminar la transmisión en texto claro en los puertos `3000`, `8000`, `8082` y `8085`:

1. Se implementó la terminación SSL centralizada en Nginx con certificados autofirmados robustos generados automáticamente en el build de la imagen (`/etc/ssl/banco/server.crt`).
2. Se aplicaron cabeceras HTTP de endurecimiento contra ataques web modernos (OWASP Top 10):

Listing 10: Cabeceras de Endurecimiento Web en Nginx

```
add_header X-Frame-Options "DENY" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always
    ;
```

4.2.6 Consolidación DEF-01: Mantenimiento del WAF Anti-SQLi y Suricata IPS

Dado que los scripts de ataque `http-sql-injection` y `http-vuln-cve2017-1001000` fallaron exitosamente debido a la intervención activa de los sistemas de defensa:

1. **Reglas WAF en Nginx:** Se conservan las matrices de coincidencia por expresiones regulares seguras en hexadecimal (`\x27`, `\x23`) que bloquean patrones de inyección SQL (`UNION SELECT`, `OR 1=1`) devolviendo `403 Forbidden`.
2. **Suricata en Modo IPS (NFQUEUE):** Se mantienen activas las firmas de intrusión bancaria con regla de acción `drop`, registrando cada intento de intrusión en `/var/log/suricata/eve.json` para su visualización inmediata en la consola web EveBox (`http://192.168.100.85:5636/`).

5. Conclusiones del Ejercicio de Auditoría

El desarrollo integral de la auditoría de seguridad y escaneo de vulnerabilidades sobre la infraestructura del servidor objetivo (`192.168.100.85`) ha permitido consolidar conclusiones técnicas y operativas de alto valor académico y profesional:

1. **Precisión del Análisis Ofensivo con Evasión Táctica:** La auditoría evidenció que los escáneres automatizados convencionales pueden ser neutralizados o degradados por mecanismos de retención (*tarpitting*) y límites de concurrencia (*rate-limiting*) implementados en Nginx y el firewall. No obstante, la aplicación de técnicas tácticas avanzadas como el escaneo con señuelos aleatorios (*Decoy Scanning* `-D RND:20`), la exclusión de sondas DoS y la restricción de tiempo por script (`--script-timeout 30s`) permitieron completar el escaneo de los 16 servicios en tan solo 49.66 segundos, demostrando que la seguridad por ofuscación o retardo es insuficiente ante auditores experimentados.
2. **Prevalencia de Fallos de Configuración y Cifrado:** Los hallazgos de severidad alta identificados en la evaluación (el intercambio anónimo Diffie-Hellman en Postfix SMTP, la exposición pública del puerto PostgreSQL en `0.0.0.0:5432` y la persistencia de verbos de depuración `DEBUG` en el servicio de Webmail) no se originaron en fallos de día cero (*0-days*) del código base, sino en omisiones de endurecimiento (*hardening*) y uso de parámetros permisivos por omisión. Asimismo, mediante la inspección forense de tráfico con Wireshark, se corroboró empíricamente la circulación de credenciales y cookies de sesión en texto plano en aplicaciones administrativas desprovistas de encapsulamiento TLS.
3. **Efectividad Comprobada del Monitoreo y Prevención (Suricata e IDS/IPS):** La integración del motor Suricata junto con la interfaz gráfica EveBox demostró una capacidad sobresaliente para decodificar flujos de red en tiempo real e interceptar sondas ofensivas de inyección SQL y explotación web. Esto ratifica que la combinación de análisis de firmas y visibilidad gráfica centralizada reduce drásticamente el tiempo medio de detección e investigación de incidentes.

4. **Complementariedad de Herramientas DAST y de Red:** El uso conjunto de Nmap para la auditoría de puertos de transporte y OWASP ZAP para el escaneo de aplicaciones web (como se demostró sobre el portal Uyuni Way en el puerto 8085) permitió una cobertura integral tanto a nivel de infraestructura como a nivel de lógica de aplicación web, visibilizando alertas que escáneres de puertos puros no logran detectar.
5. **Efectividad y Viabilidad de las Medidas de Mitigación y Endurecimiento:** La aplicación del plan de mitigación técnica propuesto —restringiendo el acceso a PostgreSQL a la interfaz local (`127.0.0.1`), limitando el procesamiento de rangos en Nginx (`max_ranges 1;`), excluyendo suites criptográficas anónimas (*aNULL*) en Postfix e imponiendo parámetros Diffie-Hellman robustos de 2048 bits— neutraliza de manera definitiva los vectores de explotación más críticos sin comprometer la continuidad de las operaciones del servidor.

5. Recomendaciones para la Infraestructura y Práctica Operativa

A partir de los resultados obtenidos y de las dificultades operativas experimentadas durante el despliegue del laboratorio, se formulan las siguientes recomendaciones estratégicas y técnicas:

1. **Superación de Limitaciones de Escenario y Adquisición de Equipamiento de Red:** Preparar un entorno de pruebas fidedigno para auditar un proyecto propio presenta una alta complejidad técnica cuando se carece de equipamiento físico dedicado de conectividad y seguridad (tales como routers corporativos, switches administrables con soporte para VLANs y firewalls de hardware dedicados). La ausencia de estos dispositivos impide la implementación de una topología de red verdaderamente funcional y segmentada (con separación estricta entre zonas DMZ, Intranet, Gestión y Base de Datos). Esto deriva en una pérdida sensible de la práctica en el diseño de arquitecturas seguras y en la formulación de políticas de filtrado

avanzadas en hardware perimetral, obligando a simular controles en entornos planos donde el tráfico de prueba interfiere con los servicios evaluados.

2. **Segmentación y Aislamiento de Red (Implementación de DMZ):** Para solventar la exposición directa de servicios críticos, se recomienda configurar interfaces virtuales (VLANs 802.1Q) o subredes Docker internas sin exposición al exterior (*internal networks*). Servicios de base de datos como PostgreSQL (5432) y herramientas administrativas como Portainer (8000) deben escuchar exclusivamente en interfaces de bucle local (`127.0.0.1`) o requerir túneles SSH/VPN para su administración.
3. **Endurecimiento Criptográfico de Protocolos de Correo y Web:** Desactivar de forma perentoria las suites de cifrado débiles y anónimas (`!aNULL:!eNULL:!ADH`) en la configuración de Postfix (`main.cf`), aplicar grupos Diffie-Hellman robustos de 2048 bits generados localmente y mitigar el vector de agotamiento de memoria Apache/Nginx ByteRange mediante la directiva `max_ranges 1;`.
4. **Auditorías Continuas con DAST y Automatización DevSecOps:** Incorporar análisis dinámicos programados con OWASP ZAP en modo demonio dentro del ciclo de desarrollo web, resolviendo las alertas de severidad media (ausencia de cabeceras de protección CSP, HSTS y fuga de métodos HTTP no requeridos) previo al paso a producción.
5. **Auditoría y Gestión de Alertas con EveBox y Suricata:** Establecer un procedimiento sistemático de revisión periódica del archivo `eve.json` mediante EveBox, creando alertas automáticas hacia el canal de administración del equipo ante la detección de anomalías de red o intentos de evasión de firewall.

Referencias

Aqua Security. (2024). Trivy: Comprehensive vulnerability scanner for containers and systems [Manual de software informático]. Descargado de https://aquasecurity.github.io/trivy/

Center for Internet Security (CIS). (2023a). *CIS debian linux 12 benchmark v1.0.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/debian_linux

Center for Internet Security (CIS). (2023b). *CIS docker community edition benchmark v1.6.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/docker

Forum of Incident Response and Security Teams (FIRST). (2019). Common vulnerability scoring system v3.1: Specification document [Manual de software informático]. Descargado de https://www.first.org/cvss/v3.1/specification-document

Greenbone AG. (2024). Greenbone community edition architecture and documentation – release 24.10 [Manual de software informático]. Osnabrück, Germany. Descargado de https://greenbone.github.io/docs/latest/

Handley, M., y Rescorla, E. (2006). *Internet denial-of-service considerations* (RFC n.º 4732). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc4732 doi: 10.17487/RFC4732

Lyon, G. F. (2009). *Nmap network scanning: The official nmap project guide to network discovery and vulnerability scanning*. Sunnyvale, CA: Insecure.Com LLC.

Open Information Security Foundation (OISF). (2024). Suricata user guide – release 7.0 [Manual de software informático]. Waltham, MA. Descargado de https://docs.suricata.io/en/latest/

Sanders, C. (2020). *Practical packet analysis: Using wireshark to solve real-world network problems* (3rd ed.). San Francisco, CA: No Starch Press.

Scarfone, K., y Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS)* (Special Publication n.º SP 800-94). Gaithersburg, MD: National Institute

of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-94/final doi: 10.6028/NIST.SP.800-94

Scarfone, K., Souppaya, M., Cody, A., y Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (Special Publication n.º SP 800-115). Gaithersburg, MD: National Institute of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-115/final doi: 10.6028/NIST.SP.800-115

Shirey, R. (2000). *Internet security glossary* (RFC n.º 2828). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc2828 doi: 10.17487/RFC2828

van der Stock, A., Glas, B., Smithline, N., y Gigler, T. (2021). *OWASP top 10: The ten most critical web application security risks* (Inf. Téc.). Open Web Application Security Project (OWASP). Descargado de https://owasp.org/Top10/